

System audit and security review

A plain-English account of what your system does, what it protects, what is built but not yet switched on, and what needs a decision from you.

Prepared for · the firm's management

Prepared by · the engineering review team

Date · 27 September 2026

Status · Audit complete; three items require your decision before the system handles real client money or real tax invoices.

How to read this document. Every technical word is explained the first time it is used, and again in the glossary on the last page. Every number quoted here was counted by a program that was run against your live system on the date above — not estimated and not typed by hand.

1 · What was reviewed, and how

This was not a reading of the code. The system was exercised: accounts were signed in to, forbidden actions were attempted deliberately, the database was queried directly, and the automated checks were run. Where this report says something is true, it is because it was tested.

Area	What it covers	Size
Database	Every table that holds firm, client, matter, document, time and money records	87 tables · 297 access rules
Firm software (back office)	The application the firm's staff use	118 endpoints · 11 screens
Client portal	The application clients sign in to	36 endpoints · 21 screens
Automated checks	Tests that assert the security rules, run on every change	21 files · 648 checks
Live environment	The deployed system and the managed database behind it	2 firms · 6 staff · 4 client users · 30 documents

2 · The short version

What is in good shape. The foundations are strong and, unusually for a system at this stage, they are enforced by the database rather than by good intentions. Client money, privileged documents, tax invoices and the audit trail are protected by rules that hold even if the application has a bug. The one unauthenticated opening that existed was found and closed during this review, and a maintenance login that could impersonate both the firm and the client was removed. 648 automated checks pass.

What needs your attention. Three things are not what they appear to be on the screen. (1) The system produces invoices with official-looking tax stamps, but the connection to the Saudi tax authority is a simulation — those are not valid tax invoices. (2) Invoices do not bill exactly what the time records say: hours are rounded before the money is worked out, which under-bills slightly on most durations. (3) Four invoices have already been shown to clients through the portal without ever being properly issued. None of these is a break-in; all three would matter in an audit or a client dispute.

Findings at a glance

Finding	Severity	Status
Internal database functions could be called by anyone on the internet, and one returned a real client money balance	Fixed in this review	Closed and verified
A leftover maintenance login could act as both the firm and the client	Fixed in this review	Removed
Restricting a matter for confidentiality recorded success without changing anything, and said the matter did not exist	Fixed in this review	Fixed at three layers, verified
A wrongly drafted invoice could not be withdrawn, leaving hours frozen forever	Fixed in this review	New feature, verified end to end

Finding	Severity	Status
Tax invoices are stamped locally but never sent to the tax authority	Needs a decision before go-live	Awaits your decision
Invoices do not bill the amount the time record states (rounded hours)	Needs a decision before go-live	Awaits your decision
Four invoices reached clients without a valid tax identity	Should be fixed before go-live	Clean-up recommended
A supporting software library has two known moderate security advisories	Should be fixed before go-live	Upgrade to schedule
Live secrets and demonstration data are still in place	Should be fixed before go-live	Before go-live
61 capabilities exist in the system with no screen to reach them	Recommended, not blocking	Roadmap

3 · Security: what protects the system

These are not features to be added later. They are in place now, and each was confirmed against the running system.

- **Nobody outside gets in without an account.** An unauthenticated visitor can read no table and — after this review — run no internal function. Before the fix, thirteen internal helpers were reachable by an anonymous caller; one of them disclosed a real client money balance of SAR 65,000. That door is closed and the closure was verified.
- **Sign-in is defensible.** Passwords are stored one-way (they cannot be read back, even by us); a wrong password and an unknown account give the identical reply, so the system cannot be used to discover who your clients are; repeated attempts are throttled and the account locks; firm staff must pass a second factor; session tokens are stored only as fingerprints.
- **The two doors never mix.** A firm credential presented at the client portal is refused exactly like a wrong password, and the reverse. Verified 6 out of 6.
- **Clients see only their own matters.** A client asking for another client's document receives the same answer as for a document that does not exist.
- **Privileged material is ring-fenced.** Documents marked privileged are withheld from clients and from unlicensed lawyers, and every read is written to the audit trail with the reason. 36 checks against the live system, all passing.
- **The two firms cannot see each other.** The second firm on the system cannot read or pay the first firm's invoice — tested, not assumed.
- **Money and tax documents are protected by the database itself.** An issued tax invoice cannot be deleted or quietly edited; a billed hour cannot be moved to another invoice or un-billed. The system's answer is a credit note, which is what your accounting rules say it should be.
- **Every important action leaves a record.** 2,391 audit entries so far, and the database refuses to let those entries be edited or deleted — including by us.

- **Uploads and web requests are contained.** Files are checked by type, size, name and actual content; uploads are limited per session; requests are rate-limited; and the browser is given strict security headers. No way to inject database commands was found anywhere in the code.

What was found and fixed during this review

What we found	What it meant	What we did
Thirteen internal database helpers were callable by an anonymous visitor. One returned a real client trust balance; others answered yes/no questions about records.	A stranger with no account could obtain financial figures or confirm guesses about your data.	Removed the default public permission on all internal helpers and granted it only to the four roles the software uses. Re-tested: every anonymous attempt is now refused.
A maintenance login (named <i>kgm_probe</i>) existed in the live database and could act as either the firm software or the client portal.	A second key to the building, cut during construction and never collected.	The login was removed. Its password must be treated as disclosed and changed wherever it may have been reused.
Restricting a matter reported success in the audit trail while changing nothing, and the screen said the matter did not exist.	A confidentiality protection that appears to work but does not — the worst kind.	Three fixes: a database rule so every matter always has its control record; a one-time backfill for existing matters (21 of 21 now complete); and the refusal moved ahead of the record so nothing untrue is ever written.
A draft invoice could not be withdrawn: its hours stayed frozen, the invoice number was consumed, and the money showed as unbilled.	A mistyped fee could only be undone with a database administrator.	Added cancellation of a draft: it keeps its record and reason, and its hours and expenses return to the unbilled list. Verified on the live system.

Still open on security

Item	Severity	What we recommend
A supporting software library (react-router) has two known moderate advisories: a crafted link could send a user to another website, and a flaw in a server-rendering mode the product does not use.	Should be fixed before go-live	Neither is reachable in the current product, and the fix is a major version upgrade that needs a test cycle. Schedule it with the next release.
The database does not record who connected, and logs only structural changes. The application keeps its own detailed trail, so nothing is missing today.	Recommended, not blocking	Turn on connection logging before go-live. It costs nothing and answers "who was in the system at 3am?".
The live configuration file holds the database password and the encryption keys that protect stored secrets. It is not in source control.	Should be fixed before go-live	Treat every secret as compromised at go-live and replace them all. This is normal at the end of a build; it is not normal to leave it.

4 · Money: the invoice does not bill what the time record says

This is the finding most likely to cost you money, and it is the one to decide on first.

A lawyer records 95 minutes at SAR 1,200 per hour. The time record stores SAR 1,900 for that work. When an invoice is drafted, the system first converts the 95 minutes into hours — and rounds it to 1.58 hours — and then multiplies: $1.58 \times 1,200 = \text{SAR } 1,896$. Four riyals have disappeared, and the invoice and your own time record now disagree about the same hour. A second example on the live system showed SAR 3,792 billed against SAR 3,800 recorded.

Why it happens. The hours figure is rounded to two decimal places before the money is calculated. Any duration that is not exactly one hundredth of an hour loses a fraction — small per line, systematic across a year, and invisible because each document looks internally consistent.

Why it matters beyond the money. The invoice is the tax document. If the amount billed does not match the firm's own record of the work, the difference has to be explained in a client query, an internal audit or a tax review.

Your decision. Either (a) bill the amount the time record states and show the hours as a description, accepting that the displayed hours will not multiply out to the halala on the page; or (b) keep the current arithmetic and require durations to be recorded in a unit that converts exactly. We recommend (a): the recorded amount is the truth, and the invoice should follow it.

5 · Built, but not switched on

These parts of the system exist, are tested, and are not connected to the outside services they need. Each is a matter of configuration and credentials rather than new development — but until then, the system is not doing the job the screen suggests.

Capability	What the system does today	What it needs
Tax invoicing (Saudi e-invoicing, "ZATCA")	Produces invoices carrying the official fields — a UUID, a counter, a hash chain position and a QR code — generated locally. The database records the firm as being in <i>production</i> mode with a placeholder tax number and no certificate. Nothing is ever sent to, cleared or reported to the tax authority.	Real tax-authority onboarding: a certificate for the firm, a registered device, and a certified connection. Until then, invoices issued here are not valid tax invoices and must not be sent to a client.
Email	Every message the system composes — client invitations, notifications, password resets — is written to the server log instead of being delivered.	An email provider account and its credentials. Nothing else changes.
Document storage	Files are saved on the server's own disk. The private cloud storage buckets exist but are empty.	The managed storage service, plus the retention and access-logging settings. For a legal practice, where documents live and for how long is a requirement, not a preference.
Card and Sadad payments	The interface offers payment methods, but no payment provider is connected, and recording a payment is a manual entry by a member of staff.	A payment provider agreement and its keys. No provider has ever delivered a payment notification to this system — the record of such events is empty.

Capability	What the system does today	What it needs
Second-factor codes	The second factor works, but in the demonstration the code is displayed on screen rather than sent to a phone.	An SMS provider, or an authenticator application (no provider needed, and more secure).

6 · What the software can do, but no screen can reach

Behind the screens, 61 capabilities are built, secured and waiting. They can be used by an engineer or another system, but a member of your staff cannot perform them. This is the largest single gap between what you have paid for and what your team can do, and it is purely a matter of building the screens.

Area	What is waiting behind the curtain	Count
Compliance and risk	Money-laundering reports to the authorities; customer due-diligence files; screening against sanctions lists and handling the results; high-risk country lists; lawyer eligibility and licence records; previous employment declarations	16
Client money (trust) accounting	Client ledgers, entries against them and the reconciliation that proves the firm's trust account balances	5
Billing, beyond drafting	Credit notes, write-offs, discounts, the firm's tax profile and devices, the submission queue and the reporting queue, and issuing an invoice from the screen	11
Client administration	Editing a client record, sending a portal invitation, and managing the parties on the other side, their alternative names and their relationships	6
Time and expenses	Recording and adjusting time and expenses from the screen, rather than through another system	6
Registers	Judgments (edit and firm-wide list), hearings and the court calendar, rate cards, engagement letters and billing terms	7

Two smaller points in the same area. Twenty-one of the seventy-five permission codes the system defines are not yet used by anything — they describe abilities (archiving a client, approving a document, exporting the audit trail) that no screen or rule currently asks for. And the firm application has no "skip to content" link, which the client portal does have; it is a small accessibility gap for keyboard users.

7 · The state of the data you would hand to a client

What is in the live system	Why it matters
Four invoices are visible to clients through the portal but were never properly issued as tax invoices (two "sent", one "paid", one "partly paid").	A client can see and even pay a document that is not valid for tax purposes. These should be written off or corrected before the system is used in earnest.
Fourteen matters had no control record, which is why restricting a matter silently failed. All 21 matters now have one.	Fixed during this review; the underlying rule is now enforced by the database.

What is in the live system	Why it matters
Ten test drafts named "LIVE-FISCAL-..." carry tax stamps. They were produced by a fiscal test rather than by real work.	They should be cleared so nobody mistakes them for real documents.
The demonstration firm, its demonstration staff, its demonstration clients and their credentials are stored in the same production database.	Before go-live this data, and those passwords, must be removed — not reused.

8 · What we changed while reviewing

These are live changes to the system and the database, each verified after it was made. Nothing here is a proposal.

- Two database updates were applied to the live database: the closing of the anonymous function access, the removal of the maintenance login, the rule that every matter gets its control record, and the permission needed for draft cancellation to release its hours. Both were dry-run first and re-verified afterwards.
- A cancelled-draft capability was completed end to end: the database rule, the service, the screen action, and 9 lines of Arabic and English wording.
- The audit-order defect in matter restriction was fixed, with a test that fails if a success is ever recorded for an action that did not happen.
- Two new tests were added (648 in total, all passing), one of which reproduces the restriction failure that was previously invisible.
- Three defects in the verification tooling itself were corrected — including one that made two client-visibility checks pass for the wrong reason, and one that caused every run to permanently consume one of the firm's recorded hours.

9 · What we recommend, in order

#	Action	Why now
1	Decide how invoices should bill rounded hours, and apply it.	It is the only finding that silently moves money, and it affects every invoice from the first day of real use.
2	Complete tax-authority onboarding before any invoice reaches a real client.	An invalid tax invoice is a compliance breach, not a display problem.
3	Clean the four un-issued client-visible invoices and the ten fiscal test drafts; then remove the demonstration firm and its accounts.	The system should not start its real life carrying demonstration records.
4	Connect the four waiting services: email, document storage, payments and e-invoicing.	Each is credentials and configuration rather than new development, and each one removes a manual step from your team's day.
5	Rotate every secret and turn on database connection logging.	Standard practice the moment a system leaves build for production.

#	Action	Why now
6	Schedule the library upgrade, and the missing screens in the order: compliance console, trust accounting, billing extras.	These are the abilities your team will ask for first, and the compliance set is the one with a legal deadline attached.

10 · Glossary, in plain English

Term	What it means
Audit trail	The permanent record of who did what, and when. This system's record cannot be edited or deleted, not even by an administrator.
Database rule (trigger)	A check that lives inside the database itself, so it applies to every program that touches the data — and cannot be bypassed by a bug in the application.
Demo / demonstration data	Sample firms, staff, clients and documents created to show the system working. They are not real and must be removed before go-live.
Hash	A one-way fingerprint of data. Passwords are stored this way: the system can check a password but cannot recover one.
Migration	A numbered, reviewed change to the database's structure or rules, applied in order and recorded so the database's history is known.
Permission code	A named ability, such as "matters.close". Every action in the system asks for one, and a role is only a bundle of them.
Row-level security	A rule that decides, per user, which individual records they may see — so a client's query cannot return another client's file even if the screen is wrong.
Session token	The temporary key a signed-in browser carries. The system stores only a fingerprint of it.
Tax identity (UUID, ICV, hash)	The fields Saudi e-invoicing requires on each invoice: a unique identifier, a sequential counter, and a link to the previous invoice so the sequence cannot be altered.
Two-factor authentication	A second proof of identity beyond the password, so a stolen password is not enough to sign in.
Webhook	A message a payment provider sends to the system to confirm money arrived, without anyone typing it in.
ZATCA	The Saudi tax authority, whose e-invoicing rules require invoices to be generated in a specific electronic form and cleared or reported to it.

The detailed engineering record of this review — every query, every failing check, and the exact state of each item above — is kept with the system as *docs/AUDIT-2026-09-27.md*. The numbers in this document are produced by the same tooling, and the report can be regenerated after any change.